SEGUNDA FASE:

DISEÑO DEL MODELO DE ADMINISTRACIÓN

Endurecimiento del acceso administrativo del servicio

Equipo: Abraham Nuñez Sanchez, Rafael Alejandro Díaz Rangel, Turan Ozbek
Fecha: 1 de octubre del 2026
Servidor: Linux con servicio web basado en WordPress

1. Introducción

El servidor Linux de la organización proporciona un servicio web basado en WordPress. Debido a que distintas personas participan en la administración, operación, soporte y respaldo del servidor, no resulta adecuado que todas las cuentas dispongan de los mismos privilegios.

El objetivo de esta fase es diseñar un modelo de administración basado en el principio de mínimo privilegio. Esto significa que cada usuario debe contar únicamente con los permisos necesarios para realizar las actividades correspondientes a su función y no debe disponer de privilegios adicionales que no necesite.

El diseño busca reducir el impacto que podría producir un error humano, una configuración incorrecta, el uso indebido de una cuenta o el compromiso de credenciales administrativas. La separación de responsabilidades también permite controlar de forma más precisa qué acciones puede realizar cada usuario dentro del servidor.

La actividad establece que el modelo de administración debe contemplar cuatro perfiles: administrador del sistema, administrador web, soporte y responsable de respaldos. Cada perfil tendrá responsabilidades diferentes y, por lo tanto, deberá contar con permisos diferentes.

2. Objetivo del diseño

Diseñar un modelo de usuarios, grupos y privilegios para el servidor Linux que permita separar las responsabilidades administrativas y aplicar el principio de mínimo privilegio.

El modelo deberá permitir que cada usuario realice las operaciones necesarias para su trabajo, pero deberá impedir aquellas acciones que se encuentren fuera de sus responsabilidades.

Además, el modelo debe permitir comprobar posteriormente que los permisos funcionan correctamente mediante pruebas positivas y negativas. Una prueba positiva comprobará que una operación autorizada puede realizarse, mientras que una prueba negativa demostrará que una operación no autorizada es rechazada. Este tipo de verificación será requerida en la siguiente fase de la actividad.

3. Principio de mínimo privilegio

El principio de mínimo privilegio establece que una cuenta solamente debe disponer de los permisos estrictamente necesarios para cumplir con sus responsabilidades.

Aplicado al servidor del caso, esto significa que no todos los usuarios deben pertenecer al grupo administrativo principal ni disponer de acceso completo mediante sudo.

Otorgar privilegios administrativos completos a todas las cuentas facilitaría algunas tareas, pero también aumentaría el impacto de un posible incidente. Si una cuenta con privilegios completos fuera comprometida, un atacante podría modificar configuraciones del sistema, crear o eliminar usuarios, acceder a información sensible, detener servicios o modificar archivos pertenecientes a otras funciones.

Por esta razón, los privilegios se separarán de acuerdo con las responsabilidades de cada perfil. Cuando una tarea requiera privilegios elevados, estos deberán proporcionarse únicamente para las operaciones necesarias, evitando en lo posible sesiones permanentes como usuario root.

El documento de la actividad señala precisamente que el diseño debe determinar qué necesita cada función y qué debe quedar explícitamente prohibido.

4. Modelo general de administración

Para la administración del servidor se propone utilizar cuentas individuales para cada persona y separar los privilegios mediante usuarios, grupos, permisos de archivos y reglas específicas de sudo.

Cada administrador deberá iniciar sesión utilizando su propia cuenta. Esto permitirá identificar qué usuario realizó cada acción y evitará el uso compartido de una cuenta administrativa.

Los grupos se utilizarán para agrupar usuarios con responsabilidades similares. La pertenencia a un grupo no otorgará automáticamente control completo del servidor, sino únicamente acceso a los recursos relacionados con la función correspondiente.

Cuando una operación necesite privilegios elevados, se utilizará sudo de manera controlada. Las cuentas que no requieran administración general del sistema no deberán disponer de acceso ilimitado mediante sudo.

De esta forma, el modelo no dependerá solamente de los nombres de las cuentas, sino de los permisos efectivos que posea cada usuario.

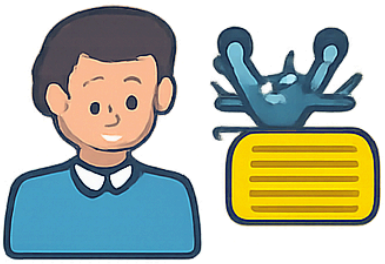
ROLES DE ADMINISTRADOR



SYSADMIN



WEBADMIN



SOPORTE TI



BDA

5. Perfil: Administrador del sistema

El administrador del sistema tendrá la responsabilidad del mantenimiento general del servidor Linux.

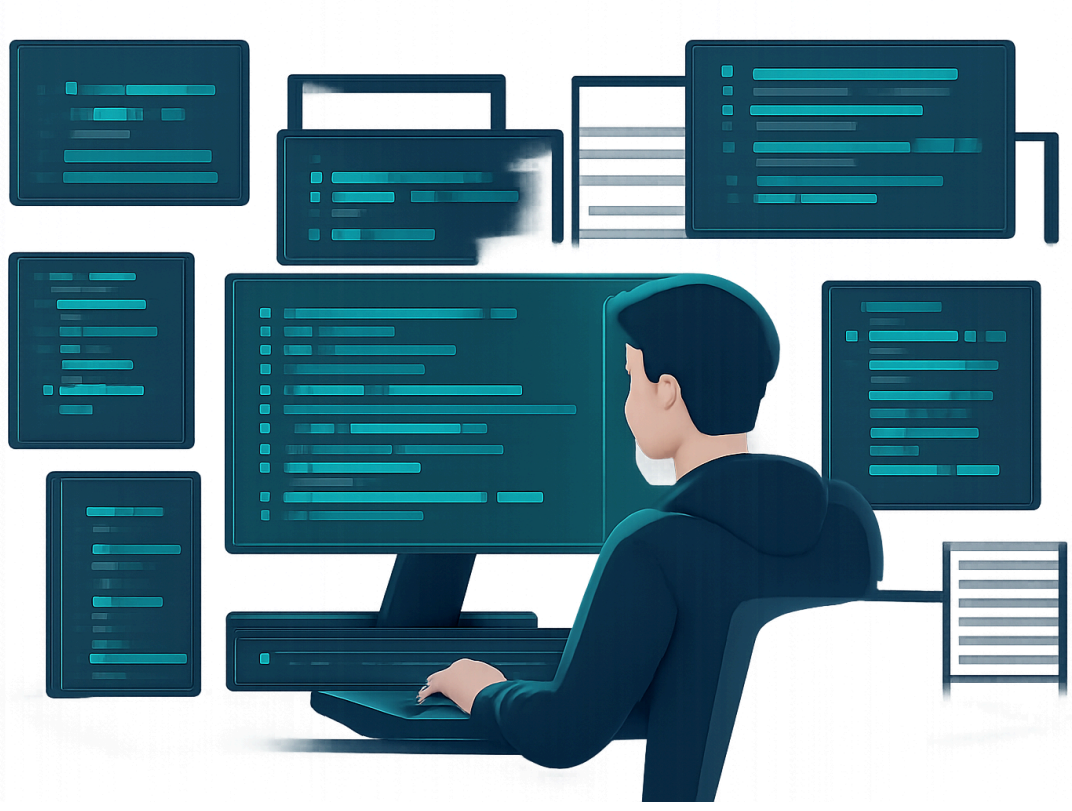
Debido a la naturaleza de sus funciones, será el perfil con mayores privilegios. Podrá realizar tareas relacionadas con configuración del sistema operativo, administración de usuarios y grupos, instalación o actualización de paquetes, mantenimiento de servicios y modificación de configuraciones administrativas.

Sin embargo, incluso este perfil deberá evitar trabajar permanentemente dentro de una sesión iniciada directamente como root.

La propuesta consiste en utilizar una cuenta personal de administrador y realizar la elevación de privilegios únicamente cuando una operación lo requiera mediante sudo.

Esto permite mantener una separación entre las actividades realizadas como usuario normal y las actividades administrativas.

El principal riesgo de este perfil es que el compromiso de su cuenta tendría un impacto elevado, debido a la cantidad de operaciones privilegiadas que puede realizar. Por esta razón, el acceso a este perfil deberá estar limitado exclusivamente al personal que realmente necesite administrar el sistema.



6. Perfil: Administrador web

El administrador web tendrá como responsabilidad principal la operación del servicio web.

Sus permisos deberán estar orientados a administrar los componentes necesarios para mantener el sitio funcionando, sin convertirlo automáticamente en administrador completo del sistema Linux.

Este perfil podrá trabajar con los archivos relacionados con el sitio web y realizar determinadas operaciones necesarias para la administración del servicio.

Sin embargo, no deberá disponer de permisos generales para crear cuentas administrativas, modificar configuraciones ajenas al servicio web o realizar cambios arbitrarios en todo el sistema operativo.

Cuando necesite ejecutar una operación privilegiada relacionada específicamente con el servicio web, podrá autorizarse mediante una regla limitada de sudo.

La finalidad de esta separación es reducir el impacto de un posible compromiso de la cuenta del administrador web. Si sus credenciales fueran obtenidas por una persona no autorizada, los permisos disponibles deberían limitar el alcance del incidente principalmente a los recursos necesarios para operar el servicio web.



7. Perfil: Soporte

El perfil de soporte tendrá como responsabilidad el diagnóstico de incidentes y fallos.

Para realizar su trabajo necesita consultar información sobre el funcionamiento del servidor y de los servicios. Por ejemplo, puede necesitar comprobar si un servicio se encuentra activo, revisar determinados registros o consultar información necesaria para identificar la causa de un problema.

Sin embargo, consultar información no implica necesariamente tener autorización para modificar la configuración del servidor.

Por esta razón, el usuario de soporte deberá disponer principalmente de permisos de consulta y diagnóstico.

No deberá tener autorización para crear usuarios administrativos, modificar configuraciones críticas, instalar software de manera arbitraria o cambiar permisos pertenecientes a otros perfiles.

La actividad utiliza precisamente el caso de soporte para ejemplificar esta separación: consultar el estado de un servicio puede estar permitido porque es necesario para el diagnóstico, mientras que crear usuarios administrativos debe permanecer denegado porque no corresponde a su función.

Esta separación es especialmente importante porque una cuenta de soporte puede utilizarse frecuentemente durante la resolución de problemas. Limitar sus privilegios reduce las posibles acciones disponibles en caso de que la cuenta sea comprometida.



8. Perfil: Responsable de respaldos

El responsable de respaldos tendrá como función ejecutar y comprobar los respaldos del servicio.

Para cumplir esta tarea necesitará acceso a la información necesaria para realizar las copias de seguridad y comprobar que los respaldos fueron generados correctamente.

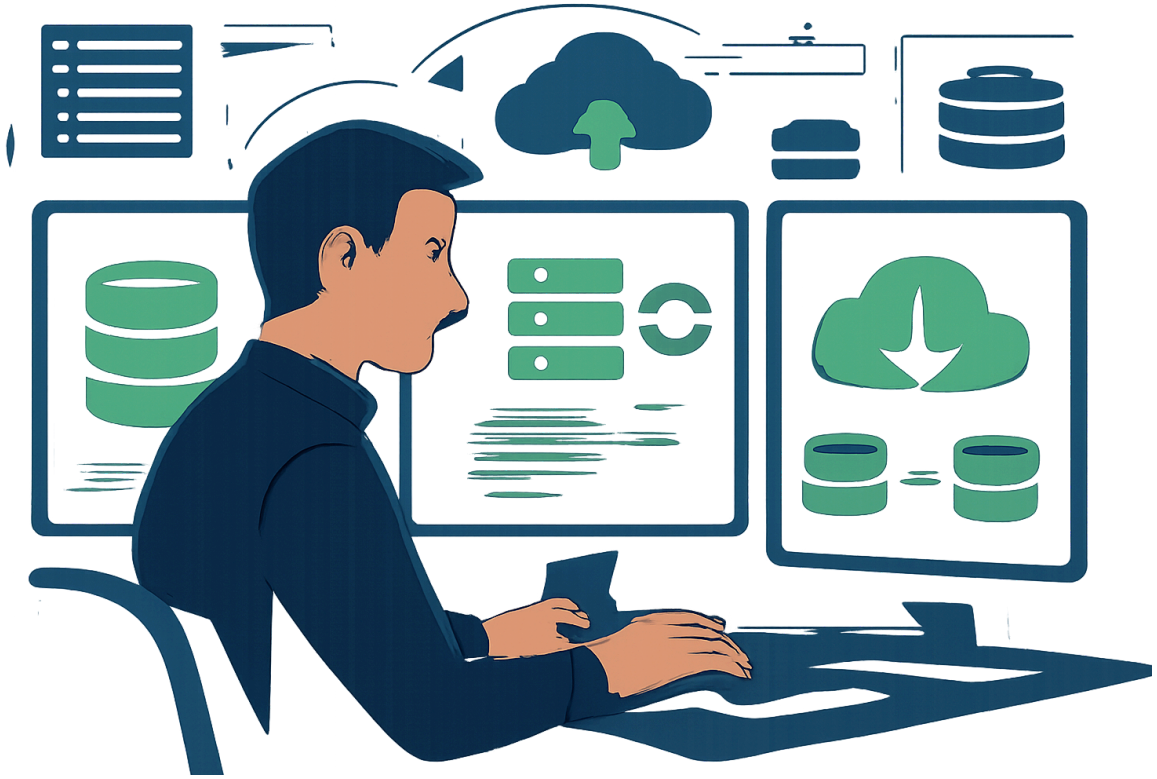
Sin embargo, la posibilidad de leer información para respaldarla no significa que el usuario necesite administrar completamente el servidor.

Por este motivo, su acceso deberá limitarse a las rutas, herramientas y operaciones necesarias para el proceso de respaldo.

Este perfil no deberá disponer de privilegios generales para administrar usuarios, modificar configuraciones del sistema operativo o realizar tareas que no estén relacionadas con el respaldo de información.

Cuando sea necesario ejecutar un comando de respaldo con privilegios elevados, se deberá autorizar específicamente esa operación, en lugar de proporcionar acceso completo mediante sudo.

Con esta separación se busca evitar que una cuenta destinada únicamente a respaldos pueda utilizarse para realizar cambios administrativos no relacionados con su función.



9. Usuarios y grupos propuestos

Para implementar la separación de responsabilidades se propone crear cuentas individuales asociadas con cada perfil.

Los grupos permitirán administrar los permisos de forma más ordenada. Por ejemplo, podrán existir grupos relacionados con administración del sistema, administración web, soporte y respaldos.

Los permisos de archivos y directorios deberán configurarse considerando propietario, grupo y otros usuarios. De esta forma, solamente los perfiles autorizados podrán acceder a determinados recursos.

La asignación exacta de usuarios y grupos deberá coincidir con la configuración que posteriormente se implemente en el servidor.

Matriz de usuarios, grupos y responsabilidades

Matriz de apoyo para el diseño del modelo de administración. Los nombres de usuarios y grupos pueden ajustarse a la configuración real del servidor.

Perfil	Usuario propuesto	Grupo propuesto	Responsabilidad principal	Acceso necesario	Acciones que deben quedar fuera
Administrador del sistema	admin_sistema	sysadmin	Mantenimiento general del servidor Linux.	Administración de usuarios y grupos, servicios, paquetes y configuraciones del sistema cuando sea necesario.	Evitar una sesión privilegiada permanente como root; usar elevación mediante sudo sólo cuando la tarea lo requiera.
Administrador web	admin_web	webadmin	Operación del servicio web basado en WordPress.	Acceso a archivos del sitio y a operaciones específicas necesarias para administrar el servicio web.	Administración general de Linux, creación de administradores y cambios arbitrarios fuera del servicio web.
Soporte	soporte	soporte	Diagnóstico de incidentes y fallos.	Consulta del estado de servicios, registros autorizados e información necesaria para diagnóstico.	Crear usuarios administrativos, instalar software arbitrariamente o modificar configuraciones críticas.
Responsable de respaldos	respaldos	backup	Ejecución y comprobación de respaldos.	Acceso a los datos necesarios para el respaldo y a las operaciones específicas de copia y verificación.	Administración completa del sistema, gestión de usuarios y cambios no relacionados con respaldos.

10. Uso de sudo y elevación de privilegios

sudo permitirá ejecutar determinadas operaciones con privilegios elevados sin necesidad de mantener una sesión permanente como root.

No todos los perfiles deberán contar con acceso completo a sudo.

El administrador del sistema podrá necesitar un conjunto amplio de operaciones administrativas debido a sus responsabilidades.

En cambio, para el administrador web, soporte y responsable de respaldos se deberán definir únicamente los comandos privilegiados que sean indispensables para sus funciones.

Cuando una operación pueda realizarse con los permisos normales del usuario o mediante permisos de grupo, no será necesario proporcionar privilegios adicionales mediante sudo.

Este diseño permitirá mantener una separación clara entre las funciones y reducirá la cantidad de cuentas capaces de realizar cambios críticos en el servidor.

11. Matriz de autorización

Antes de realizar modificaciones en el servidor se definirá qué operaciones estarán permitidas o denegadas para cada uno de los cuatro perfiles.

La matriz deberá contener el perfil, la acción necesaria, si la acción se encuentra permitida, la justificación de esa decisión y el mecanismo técnico utilizado para permitirla o impedirla.

Esta matriz funcionará como referencia durante la implementación.

La configuración real del servidor deberá coincidir con las decisiones documentadas en ella.

Matriz de autorización — Segunda fase

Producto previo a la implementación: define qué acciones necesita cada perfil, cuáles se permiten o deniegan y mediante qué mecanismo.

Perfil	Acción necesaria	Permitida	Justificación	Mecanismo
Administrador del sistema	Consultar estado de servicios	Sí	Forma parte del mantenimiento y diagnóstico general del servidor.	Cuenta individual y elevación mediante sudo cuando sea necesario.
Administrador del sistema	Administrar usuarios y grupos	Sí	La gestión de cuentas corresponde al mantenimiento general del sistema.	sudo para las herramientas de administración de usuarios y grupos.
Administrador del sistema	Instalar o actualizar paquetes	Sí	Es necesario para mantenimiento, actualizaciones y correcciones del servidor.	sudo para el gestor de paquetes.
Administrador del sistema	Modificar configuraciones del sistema	Sí	Debe poder realizar cambios necesarios para administrar el servidor.	sudo y permisos administrativos sobre los archivos correspondientes.
Administrador del sistema	Trabajar permanentemente como root	No	Mantener una sesión privilegiada permanente aumenta el impacto de errores o compromisos.	Usar cuenta personal y elevar privilegios únicamente cuando la tarea lo requiera.

Administrador web	Administrar archivos del sitio web	Sí	Es necesario para operar y mantener el servicio web basado en WordPress.	Permisos de propietario/grupo sobre las rutas del sitio web.
Administrador web	Consultar estado del servicio web	Sí	Permite verificar el funcionamiento del servicio.	Permiso de consulta o sudo específico para el servicio web.
Administrador web	Reiniciar el servicio web	Sí	Puede ser necesario durante mantenimiento o recuperación del servicio.	Regla específica de sudo únicamente para reiniciar el servicio web autorizado.
Administrador web	Crear usuarios administrativos de Linux	No	No corresponde a la operación del servicio web.	No otorgar permisos de administración de cuentas ni sudo general.
Administrador web	Instalar paquetes arbitrarios	No	Otorgaría capacidades administrativas fuera de su responsabilidad.	No permitir el uso del gestor de paquetes mediante sudo.
Soporte	Consultar estado de un servicio	Sí	Es necesario para diagnosticar incidentes y fallos.	Permitir consultas de estado sin otorgar administración general.
Soporte	Consultar registros autorizados	Sí	Los registros son necesarios para identificar errores y causas de fallos.	Permisos de lectura sobre registros específicos o grupo autorizado.

Soporte	Crear usuarios administrativos	No	No corresponde a la función de diagnóstico.	Sin privilegios para herramientas de gestión de usuarios.
Soporte	Modificar configuración crítica	No	El diagnóstico no requiere modificar configuraciones administrativas.	Permisos de archivo y sudo deben impedir la modificación.
Soporte	Instalar software	No	No es una tarea necesaria para su responsabilidad asignada.	Sin autorización para utilizar el gestor de paquetes.
Responsable de respaldos	Ejecutar respaldo autorizado	Sí	Es la responsabilidad principal del perfil.	Script o comando de respaldo previamente definido y autorizado.
Responsable de respaldos	Comprobar los respaldos	Sí	Debe verificar que los respaldos se generaron correctamente.	Acceso de lectura al destino y herramientas de comprobación necesarias.
Responsable de respaldos	Leer datos necesarios para el respaldo	Sí	El proceso de respaldo requiere acceder a los datos que se copiarán.	Permisos de lectura específicos o ejecución controlada del proceso de backup.
Responsable de respaldos	Crear usuarios administrativos	No	No está relacionado con la función de respaldos.	Sin privilegios de gestión de usuarios.

Responsable de respaldos	Modificar configuración general del sistema	No	La capacidad de respaldar información no implica administración completa.	Sin sudo general; únicamente operaciones de respaldo expresamente autorizadas.

12. Criterios utilizados para autorizar una acción

Una acción será autorizada únicamente cuando sea necesaria para que el perfil pueda cumplir con su responsabilidad.

Si una operación no está directamente relacionada con la función del perfil, deberá permanecer denegada.

También se considerará el impacto que tendría la operación si la cuenta fuera comprometida.

Por ejemplo, consultar el estado de un servicio tiene un impacto menor que modificar su configuración. De la misma manera, ejecutar una tarea de respaldo previamente definida no requiere necesariamente disponer de permisos para crear usuarios o instalar programas.

El objetivo no es impedir que los usuarios realicen su trabajo, sino proporcionar exactamente los privilegios necesarios para hacerlo.

13. Verificación prevista

Después de implementar el modelo será necesario comprobar que las decisiones de autorización realmente funcionan.

Cada perfil deberá someterse al menos a una prueba positiva y una prueba negativa.

La prueba positiva consistirá en ejecutar una operación que el perfil tenga autorizada y comprobar que puede realizarla correctamente.

La prueba negativa consistirá en intentar realizar una operación que esté fuera de las responsabilidades del perfil y comprobar que el sistema la rechaza.

La evidencia podrá obtenerse mediante salidas de comandos, archivos de configuración, registros del sistema o una demostración reproducible, tal como establece la actividad.

Matriz de usuarios, grupos y responsabilidades

Matriz de apoyo para el diseño del modelo de administración. Los nombres de usuarios y grupos pueden ajustarse a la configuración real del servidor.

Perfil	Usuario propuesto	Grupo propuesto	Responsabilidad principal	Acceso necesario	Acciones que deben quedar fuera
Administrador del sistema	admin_sistema	sysadmin	Mantenimiento general del servidor Linux.	Administración de usuarios y grupos, servicios, paquetes y configuraciones del sistema cuando sea necesario.	Evitar una sesión privilegiada permanente como root; usar elevación mediante sudo sólo cuando la tarea lo requiera.
Administrador web	admin_web	webadmin	Operación del servicio web basado en WordPress.	Acceso a archivos del sitio y a operaciones específicas necesarias para administrar el servicio web.	Administración general de Linux, creación de administradores y cambios arbitrarios fuera del servicio web.
Soporte	soporte	soporte	Diagnóstico de incidentes y fallos.	Consulta del estado de servicios, registros autorizados e información necesaria para diagnóstico.	Crear usuarios administrativos, instalar software arbitrariamente o modificar configuraciones críticas.
Responsable de respaldos	respaldos	backup	Ejecución y comprobación de respaldos.	Acceso a los datos necesarios para el respaldo y a las operaciones específicas de copia y verificación.	Administración completa del sistema, gestión de usuarios y cambios no relacionados con respaldos.

14. Impacto del compromiso de una cuenta

El modelo propuesto también permite analizar el impacto que tendría el compromiso de cada cuenta.

Si una cuenta de soporte fuera comprometida, el atacante debería encontrarse limitado principalmente a las funciones de consulta y diagnóstico autorizadas para ese perfil. No debería poder crear administradores, modificar configuraciones críticas o tomar control completo del servidor.

En cambio, el compromiso de una cuenta con capacidad administrativa tendría consecuencias mayores debido a los privilegios disponibles.

Precisamente por esta razón, la separación de funciones reduce el alcance potencial de un incidente.

El objetivo no consiste en asumir que ninguna cuenta será comprometida, sino en limitar las acciones disponibles en caso de que esto suceda.

Este planteamiento también servirá posteriormente para la fase de incidente controlado, en la que la actividad solicita comparar el compromiso de la cuenta de soporte con el compromiso de una cuenta con capacidad administrativa.

15. Riesgos residuales

Aunque se aplique el principio de mínimo privilegio, continuará existiendo riesgo residual.

Una cuenta autorizada todavía puede utilizar incorrectamente los permisos que posee. También es posible que una vulnerabilidad del sistema, una configuración incorrecta o el compromiso de una cuenta con mayores privilegios permita superar las restricciones establecidas.

Además, algunos perfiles necesitan necesariamente acceso a información o servicios importantes para cumplir sus funciones.

Por lo tanto, el mínimo privilegio reduce el impacto potencial de un incidente, pero no elimina todos los riesgos.

Será necesario complementar este modelo con otros controles de seguridad en las fases posteriores, especialmente políticas de autenticación, protección de credenciales y endurecimiento del acceso mediante SSH, aspectos que también forman parte de la actividad.

16. Conclusión

El modelo de administración propuesto separa las funciones de administrador del sistema, administrador web, soporte y responsable de respaldos.

Cada perfil recibe solamente los permisos relacionados con sus responsabilidades y se evita proporcionar acceso administrativo completo cuando no es necesario.

La utilización de cuentas individuales, grupos, permisos y elevación controlada mediante sudo permitirá aplicar el principio de mínimo privilegio.

Además, la matriz de autorización permitirá documentar claramente qué puede y qué no puede realizar cada perfil.

Posteriormente, mediante pruebas positivas y negativas, se podrá demostrar que una operación autorizada funciona y que una operación fuera de las responsabilidades del usuario es rechazada.

De esta manera, la seguridad del servidor no dependerá únicamente de que las cuentas y configuraciones existan, sino de que los controles implementados puedan comprobarse técnicamente.